Servidors web i de transferència de fitxers

Administració de servidors web

IES Daniel Blanxart

Protocol HTTP

El protocol HTTP (HyperText Transfer Protocol) estableix el protocol per a l'intercanvi de documents d'hipertext i multimèdia a la web. La seva variant segura és el HTTPS que avui dia és la que més es fa servir.





URL – URI – URN

Els localitzadors uniformes de recursos (URL) són el sistema per trobar recursos a internet utilitzant els diferents protocols existents.

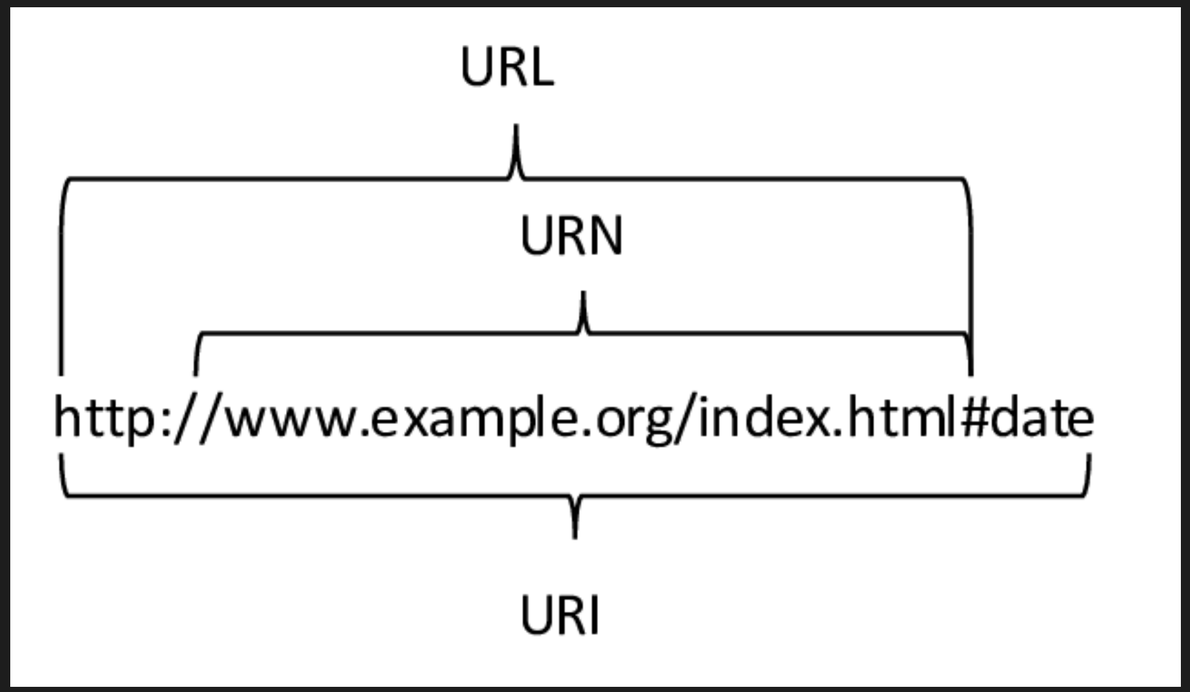
Existeix també el concepte d'identificador uniforme de recursos (URI). Teòricament, un URI és el conjunt d'un URL més un nom uniforme de recursos (URN).

No obstant això, com que el concepte URN pràcticament no s'utilitza, els termes URL i URI s'han convertit en equivalents i intercanviables en la majoria dels casos.

URL – URI – URN



- **URI** → **Identifica** un recurs, ja sigui pel seu nom, per la seva ubicació, o per ambdós. És el terme més ampli. **Totes les URL i URN són URI.**
- **URL** → Localitza un recurs, especificant on és i com accedir-hi
- URN → **Anomena** un recurs de forma única i persistent, **independentment** de la seva ubicació actual. No diu com accedir-hi.



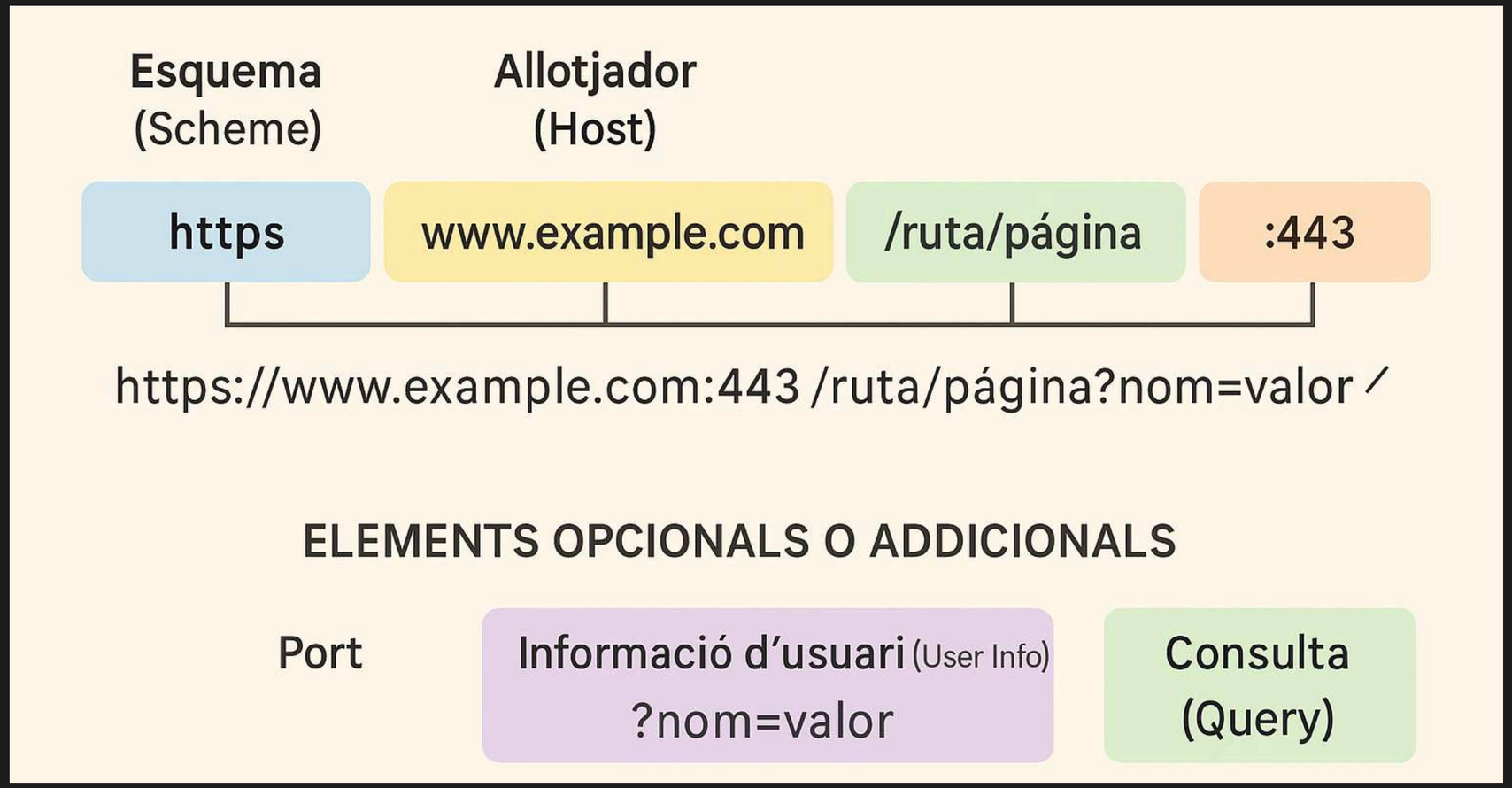
Elements de la URL

- **Elements principals**
  - **Esquema:** indica el protocol que es fara servir per accedir al recurs, segons si es HTTP o HTTPS la resta de l'URL pot tenir diferències en la seva estructura.
  - **Host**: Identifica el servidor WEB, pot ser un nom de domini o una adreça IP
  - **Path:** Indica la **localització del recurs** dins del servidor. No ha de ser necessàriament un cami físic de disc, ja que els servidors permeten crear directoris virtuals.

Elements de la URL

- **Elements opcionals**
  - **Port:** indica el **port TCP/IP** per establir la connexió, per defecte es el 80 per HTTP i el 443 per HTTPS
  - **Informació d'usuari:** no es part de la definició estàndar, alguns servidors permeten afegir el nom i la contrasenya per facilitar la identificació bàsica d'usuaris.
  - **Query**: permet passar **parametres addicionals** útils especialment per a scripts o elements que executen codi al servidor.
  - **Fragment**: Especifica una secció concreta dins del recurs identificat per l'URL. Aquesta part no s'envia al servidor, sinó que el navegador la utilitza un cop ha rebut el recurs sencer per a focalitzar la visualització a l'usuari.

Elements de la URL



URL absolut i relatiu

- **URL Absolut:** es el que inclou el nom del host i el path complet del recurs
  - https://ca.wikipedia.org/wiki/Localitzador_uniforme_de_recursos

- **URL Relatiu:** no inclou l'esquema, el host i el port. Quan un URL és relatiu s'acostuma a anomenar path i es pot dividir en:
  - **Camins complets**: comencen amb el caràcter / i especifiquen tot el directori per exemple /index.html.
  - **Camins relatius:** indica on trobar un fitxer respecte al lloc on està el document actual. És a dir, no comença des de l'arrel del servidor (/), sinó des del directori on està el fitxer HTML actual.

HTTPS

És un protocol de **petició/resposta**

Tant les peticions com les respostes HTTP comparteixen una estructura bàsica idèntica:

1. **Capçalera (Header)**: Conté metadades (informació sobre el missatge, com ara el tipus de contingut o l'estat). És alfanumèrica.
2. **Cos (Body)**: Conté el contingut real del missatge, que pot ser alfanumèric o binari.

A més, cal destacar:

- La capçalera i el cos estan separats per una línia en blanc.
- El cos és opcional; per tant, hi pot haver peticions o respostes sense contingut, només amb capçalera.



Mètodes de petició

- **Mètodes de consulta**
  - **Get**: Sol·licitar un recurs
  - **Head**: simular un GET per obtenir només metadades.
  - **Options**: Preguntar quins mètodes són permesos sobre un recurs.
  - **Tracer**: Diagnòstic (retornar la petició rebuda).
- Mètodes de Modificació
  - **Post: Enviar dades** que poden modificar l'estat o les dades del servidor
  - **Put: Crear o reemplaçar** un recurs senser a l'URL especificat
  - **Delete: Eliminar** un recurs associat a l'URL de la petició.
  - **Connect:** establir un túnel, s'utilitza per passar connexions segures SSL

Capçaleres de petició habituals

- **Host:** Idenfiticar el domini
- **User-Agent:** Identificar el programari client
- **Accept**: Indicar els tipus MIME de dades suportats.
- **Accept- Language**: Indicar els idiomes preferits
- **Accept-Charset**: Indicar els jocs de caràcters preferits
- **Accept-Encoding**: Indicar els tipus de compressió suportats
- **Referer**: Indicar l'URL d'origen de la petició
- **Content-Type**: Indicar el tipus MIME del cos de la petició.
- **Content-Length**: Indicar la mida del cos de la petició
- **Connection**: Gestionar l'estat de la connexió.

Codis d’estat

- **1xx:** de tipus informatiu, informen el client que la petició ha estat rebuda i que el servidor continua processant la resposta.
- **2xx:** indiquen la petició ha estat correcta i s’ha processat satisfactòriament
- **3xx:** indiquen alguna forma de redirecció. Es dona a entendre al client que la petició és correcta però que la resposta s’ha d’obtenir d’algun altre lloc.
- **4xx:** indiquen que hi ha hagut una errada en el processament de la petició perquè el client ha fet alguna cosa malament, l’error ha estat causat pel client.
- **5xx:** indiquen que hi ha hagut una errada en el processament de la petició
- a causa d’una fallada en el servidor, l’error ha estat causat pel servidor.

Capçaleres de resposta

- **Content-type**: Indicar el tipus de contingut del cos de la resposta.
- **Date:** Indicar la data i hora d'enviament.
- **Last-Modified**: Indicar la data de l'última actualització del recurs.
- **ETag**: Proporcionar una etiqueta d'entitat (hash o checksum) del recurs.
- **Server**: Identificar el programari i la versió del servidor.
- **Location**: Indicar la nova adreça (URL) del recurs, s'utilitza en respostes de redirecció

https://www.supermonitoring.es/blog/consultar-encabezados-redirecciones-http/

Apache



Apache és un servidor HTTP de codi obert multiplataforma, presenta missatges d'error configurables, bases de dades d'autenticació i negociació de continguts, pero no te una interficie gràfica que ajudi a configurar-lo

Configuracio d'Apache

El directori on hi ha les configuracions és **/etc/apache2** i el fitxer principal és **apache2.conf**
Dins de la configuració inicial, es poden trobar algunes de les directives més importants:

- Gestió de temps d'espera i connexions:
  - **Timeout:** Defineix el temps (en segons) màxim d'espera per rebre i enviar dades durant una operació.
  - **Keep-alive:** Habilita o deshabilita les connexions persistents
  - **MaxKeepAliveRequests:** Estableix el nombre màxim de peticions que es permeten durant una única connexió persistent.
- **KeepAliveTimeout:** Temps (en segons) que el servidor espera la següent petició d'un client a través d'una connexió persistent.

Configuracio d'Apache

- Estructura, Fitxers i Rutes:
  - **DocumentRoot:** Defineix la ruta al directori arrel del lloc web principal o per defecte del servidor.
  - **Directory:** Defineix un bloc d'opcions de configuració per a un directori del sistema de fitxers específic.
  - **DirectoryIndex:** Especifica quins documents es mostraran per defecte (p. ex., index.html) quan es sol·licita un URL sense un fitxer concret.
  - **AccessFileName:** Nom del fitxer (p. ex., .htaccess) que el servidor ha de buscar a cada directori per a configuracions addicionals.
  - **ErrorLog:** Defineix la ubicació de l'arxiu de registre d'errors del servidor.
  - **Include module configuration:** Camí on es troba el fitxer que llista els mòduls disponibles i actius (p. ex., /mods-enabled).
  - **Include list of ports to listen:** Camí on es troba el fitxer que especifica els ports TCP d'escolta del servidor (p. ex., port 80 i 443).
  - **Include the virtual host configurations:** Camí on es troba el fitxer de configuració per als servidors virtuals (Virtual Hosts).

Configuracio d'Apache

- Directory
- DirectoryIndex:
- AccessFileName:
- Include the virtual host configurations
- User
- Group:

Mòduls de Apache

La gran majoria de servidors web permeten la instal·lació de mòduls per ampliar les seves funcionalitats.

Tenir funcionalitats en forma de mòdul permet adaptar millor el consum de recursos del servidor web a les nostres necessitats de producció (el servidor web només carregarà i executarà els mòduls que com a administradors tenim instal·lats i configurats).

El fitxer del mòdul (habitualment el nom sol començar per mod i acabar en .so) es guarda al directori /usr/lib/apache2/modules.

Per saber quins mòduls hi ha disponibles per instal·lar al servidor, amb el gestor de paquets APT podeu executar la comanda **apt-cache search libapache2-mod**. Es mostrarà un llistat amb el nom del mòdul i una petita descripció de cadascun.



Activació i desactivació de mòduls

L'administració d'Apache permet tenir mòduls instal·lats però no activats. Per fer que un mòdul entri en funcionament cal activar-lo, un procés que implica fer-lo accessible des de la configuració principal.

L'activació d'un mòdul consisteix a crear enllaços simbòlics (accesos directes) des del directori de mòduls disponibles cap al directori de mòduls habilitats, permetent que el servidor els carregui en iniciar-se.

Es pot fer de forma manual i requereix crear enllaços simbòlics dins de /etc/apache2/mods-enabled apuntant als fitxers de configuració disponibles a /etc/apache2/mods-available

També es pot fer de forma automàtica amb **a2enmod [nom_del_mòdul]**

Un cop activat el mòdul, cal **reiniciar o recarregar** el servei d'Apache perquè els canvis de configuració tinguin efecte.

Servidors virtuals



El concepte de Servidors Virtuals (Virtual Hosts o vhosts, en terminologia d'Apache) permet que un únic servidor físic actuï com si fossin diversos servidors web independents, oferint llocs web diferents.

Mecanisme d'Funcionament

El servidor virtual s'aconsegueix gràcies a la col·laboració de:

1. Protocol DNS: Permet que diversos noms de domini (p. ex., webA.com i webB.com) apuntin a la mateixa adreça IP del servidor físic.
2. Capçalera Host (HTTP): El client (navegador) envia aquesta capçalera en la petició per indicar al servidor quin nom de domini està intentant accedir. El servidor utilitza aquesta informació per saber quin lloc web específic ha de servir.

Tipus de Servidors Virtuals

- **Basats en IP:** S'assigna una adreça IP única a cadascun dels servidors virtuals allotjats.
- **Basats en Nom:** Múltiples llocs virtuals comparteixen la mateixa adreça IP, diferenciant-se únicament pel nom de domini especificat a la capçalera Host. (Aquest és el mètode més comú i eficient en l'ús d'IPs).

Passos per crear i posar en marxa un vhost

1. Aneu al directori /etc/apache2/sites-available. Aquesta carpeta conté els fitxers de configuració per a cadascun dels servidors virtuals disponibles al servidor.
2. Creeu un nou fitxer de configuració del lloc web amb el nom que vulgueu, dins del mateix directori.
3. Afegiu les opcions per adaptar-lo a les necessitats del nou servidor virtual dintre d'aquest fitxer.
4. Creeu l'enllaç simbòlic dintre la carpeta /etc/apache2/sites-enabled que apunti cap al fitxer de configuració del servidor virtual creat a la carpeta /etc/apache2/sites-available. O bé useu l'ordre a2ensite nom_fitxer_servidor_virtual.conf.
5. Executeu l'ordre service apache2 reload. Aquesta ordre força al servidor Apache a tornar a carregar la seva configuració.
6. Comproveu com respon el servidor facilitant el llocweb corresponent a cada servidor virtual.

Permisos

Cal tenir presents algunes qüestions relatives als permisos d’accés a carpetes i fitxers:

- Al directori /etc/apache2 hi ha un fitxer anomenat envvars on, entre d’altres aspectes, es defineix el nom d’usuari i el grup amb el qual treballarà el servidor Apache.
- Per defecte trobarem:
  - export APACHE_RUN_USER=www-data
  - export APACHE_RUN_GROUP=www-data
- Això indica que el servidor Apache accedirà a arxius i directoris utilitzant l’usuari www-data i el grup www-data. Tenint en compte aquest tema, caldrà donar permís de lectura als fitxers (r–) i accés als directoris (r-x), com a mínim, a aquest usuari/grup a tots els directoris i fitxers que formin part dels llocs web que serveixi Apache.

Autenticació i control d'accés

1. Mecanismes Integrats
   - El servei web (com Apache) ja incorpora **mecanismes bàsics** de verificació, aquests mecanismes són suficients per a la majoria de necessitats, com ara restringir l'accés al material intern (p. ex., un directori de professors en un web d'escola) utilitzant:
     - Verificació d'Usuaris
     - Verificació de Grups
2. Flexibilitat i Ampliació (Mòduls):
   - La capacitat del servidor web per utilitzar mòduls permet una gran flexibilitat per incorporar mecanismes d'autenticació i autorització més complexos. Per a entorns d'alta seguretat (com una agència governamental), es podrien incorporar mecanismes addicionals basats en **factors biomètrics com l'empremta òptica o el registre de veu.**

Mecanismes de validació general

- **Autenticació bàsica amb fitxers**: Aquest és el mecanisme més simple per implementar el control d'accés utilitzant fitxers d'usuaris i grups propis del servidor web. S'utilitzen fitxers d'usuaris i grups gestionats pel servidor web.
  - **Avantatge**: Facilitat d'administració
  - **Inconvenient**: Comporta una gestió diferenciada dels usuaris del servei web respecte als usuaris del sistema operatiu
- **Autenticació mitjançant PAM**: Aquest mètode integra l'autenticació del servidor web amb els mecanismes d'autenticació del sistema operatiu GNU/Linux. PAM és un sistema modular que pot comprovar múltiples fonts de credencials de forma centralitzada
- **Autenticació mitjançant LDAP** un dels mecanismes més populars i potents actualment per a l'autenticació d'usuaris en un servidor web. Pot operar de dues maneres:
  - Integració amb el sistema central: passar la validació a un servidor LDAP que gestiona tots els usuaris del sistema, aixo ens permet una gestío unificada de les identitats Servei LDAP específic.

Autenticació i Autoritzacio

- **Autenticació:** Determina si un usuari és qui diu ser. No governa drets d'acces. Aixo es pot fer desde una simple contrasenya fins a mecanismes com les emprentes digitals, claus USB etc
- **Autorització:** Determinar els drets d'utilització dels recursos. Es duu a terme un cop l'usuari ha estat autenticat. Respon a la pregunta: "Què pot fer aquest usuari?"
- **“Ámbito”:** en una seu web hi poden haver diverses àrees restringides a perfils d'usuari diferents. Els ambits permeten definir quines àrees restringides comparteixen el mateix grau d'accés.

Web amb inici de sessió: un error típic és confondre l'autenticació amb l'autenticació de programari

Mòduls de control d'accés



Cada mòdul consta d'un conjunt de directives que permeten configurar el funcionament de l'autenticació i control d'accés implementats. Aquests mòduls es poden classificar en tres categories segons la seva funcionalitat:

- **Tipus d'autenticació**: basic o digest, la digest es xifrada
- **Proveïdor d'autenticació**: Són els mòduls que permeten autenticar usant fitxers de contrasenyes o el mòdul PAM o el de LDAP.
- **Autorització** proporcionen autorització d'usuari, de grups, del LDAP o del que convingui.

Autenticació bàsica amb fitxers

Amb l'autenticació bàsica utilitzant fitxers es poden validar els usuaris utilitzant un fitxer d'usuaris, que conté els comptes d'usuaris i les seves contrasenyes.

També es poden validar grups d'usuaris amb un fitxer de grups, que indica quins usuaris formen part de cada grup.



El protocol HTTPS

El protocol HTTP (igual que protocols antics com FTP i SMTP) pateix un problema fonamental de seguretat: tota la informació viatja en text pla (plain text).

- Això fa que les dades siguin fàcilment monitorables i capturables per tercers (p. ex., contrasenyes, dades bancàries o qualsevol informació privada).
- Per tant, l'ús d'HTTP és desaconsellable per a la transmissió de qualsevol dada sensible.

El mecanisme de seguretat implementat per xifrar la comunicació HTTP és el protocol SSL (Secure Socket Layer) / TLS (Transport Layer Security) (Secure Socket Layer)

- L'SSL/TLS proporciona una capa de xifratge entre la capa de transport (TCP) i la capa d'aplicació (HTTP). Totes les dades que hi passen són xifrades.